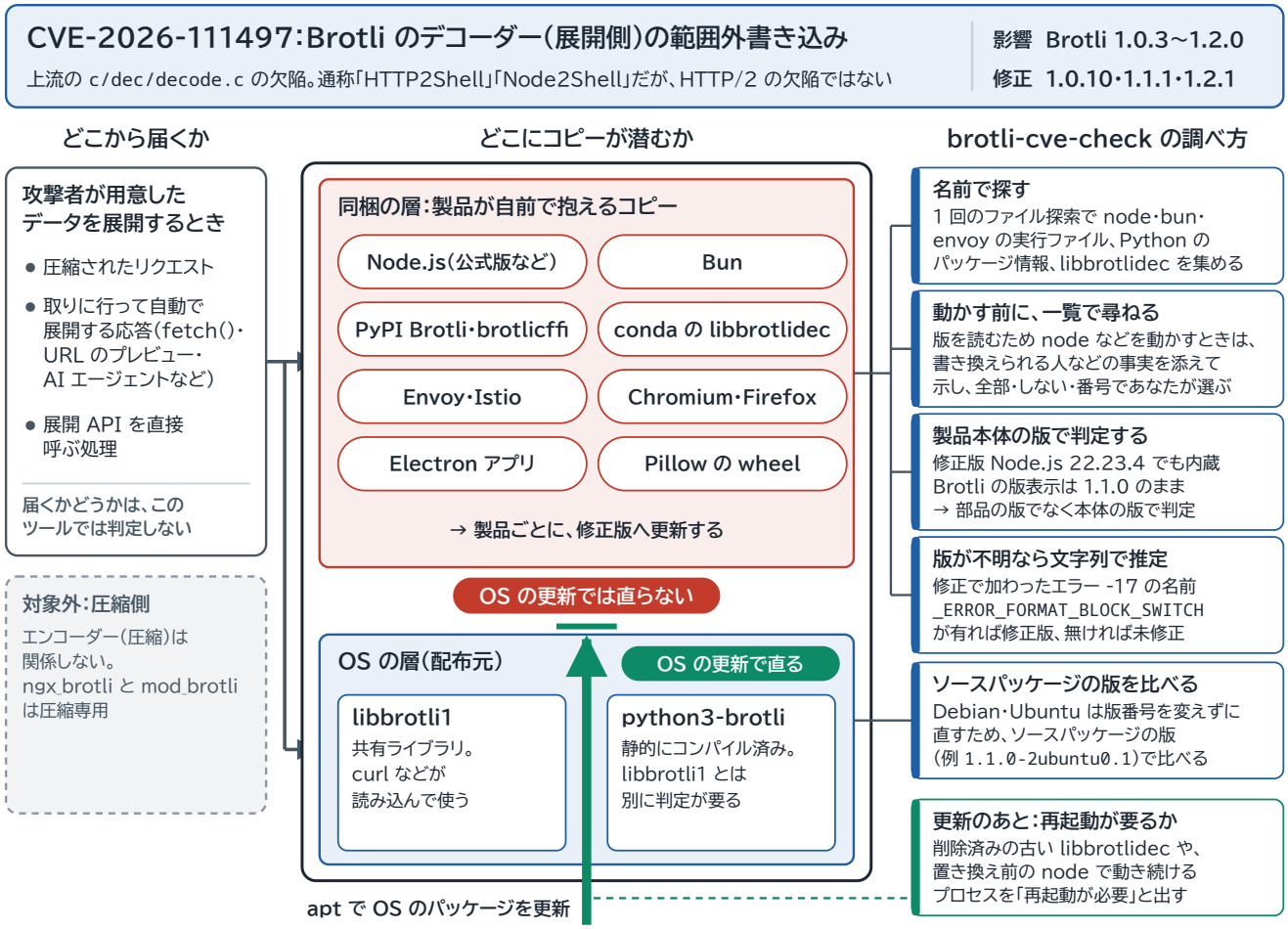
図解 01　何を、どのようにチェックしたか　CVE-2026-111497



この1枚の読み方

1. **弱点は展開側(デコーダー)にあり、攻撃者のデータが展開されるときに届く。**届き方は、圧縮されたリクエスト、ホストが取りに行って自動で展開する応答(`fetch()`・URL のプレビュー・Web の収集・AI エージェント)、展開 API を直接呼ぶ処理とさまざま。このツールはコピーの**棚卸し**までで、そこにデータが届くかは判定しない(判断は使う人)。上流は 2026-10-21 に修正した(GHSA-9v8h-qqgm-4m35)。

2. **同梱コピーは製品ごとの更新が要る**(**OS の更新では直らない**)。修正版の例: Node.js 22.23.4・24.22.1・26.12.1、Bun 1.4.4、PyPI の Brotli 1.2.1。文字列による推定は Brotli 1.2.0／1.2.1 の自前ビルド、Node.js 公式バイナリ、PyPI の wheel で確かめ、エラー名の表が削られたビルドは修正済みとせず `VENDORED_COPY`(要確認)と出す。OS のパッケージは Ubuntu(USN-8956-1)も Debian(DLA-4855-1・DSA-6582-1)も修正版が出ている。

3. **ツール自身はソフトも設定も変えず、「安全」とは表示しない。事実を示し、判断はあなたがする。**書き込むのは標準出力と `--output` だけで、ツール自身はネットワークにつながず、攻撃データも使わない。見つけたプログラムは、選ばれたものだけを版の引数 1 つ(`--version` など)で、`/` から・環境変数を空・標準入力を閉じ・制限時間と出力の上限つきで、あなたの権限で動かす(その動きまでは止めない)。端末が無ければ `--yes` か `--no-exec` が要る。何を動かし、何を動かさなかったかは結果に出る。コンテナは docker・podman の接続先と一緒に出し、中を見るのは接続先がこのホストの unix ソケットのときだけ。`EXPOSURE` は届く経路の手がかりで、脆弱性ではない。侵入の有無は調べない。

OS の更新が直すのは OS のコピーだけで、同梱コピーは版と文字列で一つずつ洗い出す。

処方箋　SHA256 を確かめてから `sudo bash brotli-cve-check --lang ja` を走らせ、実行してよいか尋ねられたら一覧の事実を読んで選び、「更新が必要なもの」「再起動が必要なもの」から更新・再起動する。